



بنك الأفاق

AL-AFAQ BANK

Global Horizon Banking | أفاق عالمية | سلامة استثمارية ..

منهجية تقييم ومعالجة مخاطر أمن المعلومات (Security Risk Assessment & Treatment Methodology)

التصنيف (Classification):

داخلي (Internal) — لا يجوز مشاركة هذه الوثيقة داخلياً أو خارجياً دون موافقة مسبقة من مالك الوثيقة.

الإصدار	معتمد من	مالك الوثيقة	تاريخ آخر تحديث	دورية المراجعة	المراجعة القادمة	الملاحظات
1.0	د. نورة القحطاني (الرئيس التنفيذي) أ. عبدالله المحيسن (رئيس مجلس الإدارة)	أ. سارة الحربي (مدير أمن المعلومات - CISO)	11-09-2026	سنوي	سبتمبر 2027	المنهجية المعتمدة لتقييم ومعالجة مخاطر أمن المعلومات لبنك الأفاق الرقمية وفق ISO/IEC 27001:2022 (إعداد: محمد العامري، محمد الكشيري، محمد شماخ، محمد الأصبحي)

المحتويات

- الغرض من هذا المستند.....1
- سجل المخاطر.....2
- الأدوار والمسؤوليات.....2
- ملخص المنهجية.....2
- تحديد المخاطر.....3
- خطط المعالجة.....8
- التصعيد.....8

الغرض من هذه الوثيقة (Purpose of This Document)

يوضح هذا المستند النهج العام لأمن المعلومات داخل بنك الأفاق الرقمية.

وهو مخصص لتقديم إرشادات وتوجيهات حول الجوانب الحيوية لإدارة المبادئ الأساسية لمخاطر أمن المعلومات.

هذا المحتوى موجه للموظفين، والمدققين، والموردين، والعملاء. ويمكن الاطلاع على مزيد من التفاصيل الداعمة في السياسات والإجراءات المشار إليها.

سجل المخاطر (The Risk Log)

يمكن العثور على سجل مخاطر أمن المعلومات في بوابة نظام إدارة أمن المعلومات.

يقتصر الوصول إلى سجل المخاطر بشكل صارم على الفئات التالية وبالصلاحيات المحددة أدناه:

- مدير أمن المعلومات (أ. سارة الحربي) وفريق تقييم المخاطر والثغرات: صلاحية تعديل وتحكم كامل (Full Control / Read & Write) لإدارة وتحديث السجل ومتابعة خطط المعالجة.
- مالكو المخاطر ورؤساء الأقسام (مديرو البنية التحتية، التطبيقات، العمليات، المالية، الموارد البشرية): صلاحية تعديل محصورة (Contribute / Edit) فقط لحقول المخاطر وخطط المعالجة التابعة لإداراتهم وأصولهم التشغيلية المحددة.
- الإدارة التنفيذية العليا (د. نورة القحطاني)، إدارة المراجعة الداخلية (أ. أحمد الغامدي)، وإدارة الالتزام والحوكمة: صلاحية قراءة واطلاع فقط (Read-Only) لأغراض الرقابة، والمتابعة التنفيذية، وإعداد تقارير اللجان والمراجعة المستقلة.
- الأطراف الخارجية والموردون: يحظر حظراً تاماً تصدير السجل أو مشاركته مع أي طرف خارجي دون موافقة خطية مسبقة من CISO.

الأدوار والمسؤوليات (Roles & Responsibilities)

تتوزع الأدوار والمسؤوليات المنوطة بتطبيق منهجية تقييم ومعالجة المخاطر على النحو التالي:

لجنة أمن المعلومات والمخاطر - Information Security Group (ISG):

- وضع واعتماد سياسة إدارة المخاطر، والأهداف الأمنية، وتحديد الشهية للمخاطر (Risk Appetite) في البنك.
- تخصيص وتوفير الموارد والميزانيات اللازمة لدعم تنفيذ خطط معالجة المخاطر (ضمن ميزانية الـ 18 مليون ريال المعتمدة).
- ضمان موازنة أنشطة معالجة المخاطر مع الأهداف الاستراتيجية والتجارية العامة لبنك الأفاق الرقمية ومتطلبات البنك المركزي السعودي.

مالكو المخاطر والأصول - Risk Owners:

- تحديد وتقييم المخاطر الأمنية المرتبطة بمجالات مسؤولياتهم وأصولهم التشغيلية والتقنية المحددة.
- تحديد معايير المخاطر ومستويات الخطر المقبولة ضمن نطاق إداراتهم.
- اختيار خيارات المعالجة الأنسب (القبول، التجنب، النقل، أو التخفيف) بناءً على الشهية المعتمدة للمخاطر وتكلفة المعالجة.
- تنفيذ ومراقبة خطط معالجة المخاطر والإشراف المباشر على تطبيق الضوابط التخفيفية.
- رفع تقارير دورية لإدارة أمن المعلومات حول مدى التقدم في معالجة المخاطر وإغلاق الفجوات.

مدير وضباط أمن المعلومات - Information Security Officer (ISO / CISO):

- تطوير وصيانة منهجية معالجة وتقييم المخاطر والأدوات والتقنيات والنماذج المرتبطة بها (بإشراف أ. سارة الحربي).
- تقديم التوجيه والدعم الاستشاري والتقني لمالكي المخاطر وأصحاب المصلحة خلال كافة مراحل إدارة المخاطر.
- المراقبة المستمرة لفاعلية وتطور خطط المعالجة وقياس المخاطر المتبقية (Residual Risks).

- إعداد ورفع تقارير دورية عن وضع المخاطر للإدارة العليا ولجنة أمن المعلومات ومجلس الإدارة.
- تنسيق وإدارة أنشطة المعالجة المشتركة بين الفرق الفنية والإدارية.
- تنسيق أعمال فريق الاستشارات (محمد العامري، محمد الكشري، محمد شماخ، محمد الأصبحي) لبناء وتحديث السجلات وفق ISO 27001:2022.

ملخص المنهجية (Summary of approach)

تنقسم منهجية إدارة وتخفيف المخاطر (Risk Management and Mitigation) في بنك الأفاق الرقمية إلى خمس خطوات رئيسية مترابطة:

الخطوة	اسم المرحلة	الهدف والنشاط الإجرائي في بنك الأفاق الرقمية
01	تحديد المخاطر	حصر أصول المعلومات المصرفية والأنظمة وقواعد البيانات وتحديد التهديدات ونقاط الضعف الناتجة عن الحوادث والبيئة التشغيلية.
02	تقييم المخاطر	تقدير مستوى الاحتمالية ومستوى الأثر لكل خطر محدد باستخدام مقياس كمي ونوعي خماسي المستويات (1 إلى 5).
03	تحديد الأولويات	احتساب درجة الخطر الإجمالية (الاحتمالية × الأثر) وتصنيفها على مصفوفة المخاطر 5×5 للتركيز على المخاطر الحرجة والعالية.
04	معالجة المخاطر	تطوير وتطبيق استراتيجيات المعالجة (تخفيف، تجنب، نقل، قبول) عبر ضوابط الملحق A لمواصفة ISO 27001:2022.
05	مراقبة المخاطر	المراقبة والتقييم المستمر لفاعلية الضوابط المنفذة وتحديث سجل المخاطر دورياً لمواكبة التهديدات السيبرانية المستجدة.

تحديد المخاطر (Risk Identification)

يمكن تحديد المخاطر الأمنية من خلال عدة طرق. وتشمل هذه الطرق داخل بنك الأفاق الوقمية، على سبيل المثال لا الحصر، ما يلي:

- المراجعة السنوية لسياق المنظمة: أي تغييرات تطرأ على النطاق، أو الأطراف المعنية، أو التشريعات والتي قد تؤدي إلى ظهور مخاطر جديدة.
- مراقبة التهديدات الناشئة: من خلال تنبيهات الموردين حول التهديدات الأمنية، والمستجدات المنشورة في وسائل الإعلام، والإشعارات الصادرة عن جهات وهيئات مثل المركز الوطني للأمن السيبراني في المملكة المتحدة (NCSC).
- تحليل SWOT: أسلوب لمراجعة نقاط القوة، ونقاط الضعف، والفرص، والتهديدات الخاصة بالمنظمة. وتجري بنك الأفاق هذا التقييم للتهديدات الهامة بصفة سنوية.
- إشراك الأطراف المعنية: الملاحظات والآراء الواردة من الموظفين داخل المنظمة وخارجها.
- عمليات التدقيق الأمني: عمليات التدقيق الخارجي، واختبارات الاختراق، وفحص الثغرات الأمنية. تستعين بنك الأفاق بالتدقيق الخارجي وتجري اختبارات اختراق سنوية.
- تقييم مخاطر الأنظمة الحساسة (الحرجة): مراجعة شاملة وتفصيلية للمكونات والمخاطر المحتملة التي قد تؤثر على استمرارية تشغيلها.

يجب الإبلاغ عن المخاطر إلى مكتب المساعدة (Help Desk) (إذا كانت واردة من خارج إدارة تقنية المعلومات) وتسجيلها في "سجل المخاطر" (Risk Log)، والذي يُعد المرجع الموثوق والوحيد لتفاصيل المخاطر وخطة معالجتها خلال مراحل عملية المعالجة.

تقييم المخاطر (Risk Assessment)

يتم تقييم كل خطر محدد بناءً على احتمالية وقوعه (Likelihood) والأثر المحتمل المترتب عليه (Impact). تشير الاحتمالية إلى فرصة حدوث الخطر، بينما يمثل الأثر العواقب والنتائج المحتملة في حال تحقق الخطر. اعتمد بنك الأفاق الرقمية مقاييس القياس الخماسية التالية:

مقياس الاحتمالية (Likelihood):

الدرجة (Score)	الوصف التفصيلي (Description)	مستوى الاحتمالية (Likelihood)
1	من غير المحتمل إطلاقاً حدوث الخطر في ظل الظروف الطبيعية. لا توجد حالات مسجلة أو حالات نادرة جداً في مؤسسات مماثلة في القطاع المالي. يخصص هذا المستوى للمخاطر النظرية أو المهمة (مرة كل 5 سنوات أو أكثر).	نادر جداً (Remote)
2	فرصة حدوث الخطر منخفضة. قد يحدث في ظروف استثنائية طارئة ولكن لا يتوقع حدوثه بانتظام. يخصص للمخاطر المعترف بها ولكنها غير شائعة في البيئة المصرفية الحالية (مرة كل 2 إلى 3 سنوات).	غير مرجح (Unlikely)
3	احتمالية معتدلة للحدوث. توجد فرصة متساوية لحدوث الخطر أو عدم حدوثه. يمثل إمكانية واقعية في بيئة العمل الحالية ويجب منحه قدرًا مناسباً من الاهتمام والمتابعة (مرة سنوياً).	محتمل (Possible)
4	احتمالية وقوع الخطر تفوق عدم وقوعه. توجد سوابق لتحقيق هذا الخطر في سياقات مماثلة، أو توجد عوامل وفجوات بينية حالية تزيد من فرصة وقوعه. يتطلب إدارة استباقية ومراقبة لصيقة (عدة مرات سنوياً).	مرجح (Probable)
5	الخطر شبه مؤكد الحدوث بشكل متكرر. توجد أدلة قاطعة أو بيانات تاريخية حاسمة تؤكد تكرار هذا الخطر في البنك. يشير إلى خطر عالي الأولوية يتطلب إجراءات تخفيف فورية وفعالة (أسبوعياً أو شهرياً).	شبه مؤكد (Highly Probable)

مقياس الأثر (Impact)

الدرجة (Score)	الوصف التفصيلي والتأثير المصرفي (Description)	مستوى الأثر (Impact)
1	أثر مهم؛ لا تترتب عليه عواقب ملحوظة على العمليات التشغيلية، السمعة، أو المركز المالي للبنك. لا يسبب أي انقطاع في الأعمال الاعتيادية ولا يتطلب جهداً يذكر لمعالجته (خسائر أقل من 50,000 ريال).	ضئيل (Insignificant)
2	يسبب إزعاجاً طفيفاً يمكن إدارته وحله بسهولة عبر الإجراءات الروتينية. قد يؤدي لتأخير بسيط أو تكاليف طفيفة، ولكنه لا يؤثر جوهرياً على العمليات أو أهداف البنك (خسائر 50,000 - 250,000 ريال).	منخفض / طفيف (Minor)
3	أثر ملموس يسبب بعض التعطل في الخدمات ولكن يمكن تجاوزه والتعامل معه دون صعوبة بالغة. قد يتضمن تكاليف مالية معتدلة، انخفاضاً مؤقتاً في الإنتاجية، أو ضغطاً على الموارد (خسائر 250,000 - 1,000,000 ريال).	متوسط (Moderate)
4	تعطل جسيم في الخدمات المصرفية أو العمليات الحيوية. قد ينتج عنه خسائر مالية كبيرة، ضرر بالغ بسمعة البنك، أو تطلب تخصيص موارد استثنائية للمعالجة. التعافي يتطلب جهداً كبيراً وقد يؤثر على الخطط	كبير / عالي (Major)

	الاستراتيجية (خسائر 1 - 5 ملايين ريال).	
5	أثر بالغ الخطورة يهدد وجود البنك واستمرارية أعماله. يؤدي إلى أضرار طويلة الأجل أو دائمة في السمعة والاستقرار المالي، أو سحب الترخيص المصرفي، وعقوبات تنظيمية وقانونية صارمة، وتضرر العلاقات مع الشركاء (خسائر تتجاوز 5 ملايين ريال).	كارثي (Catastrophic)

تحديد أولويات المخاطر (Risk Prioritisation)

يقوم بنك الأفاق الرقمية بترتيب وتصنيف المخاطر بناءً على حاصل ضرب درجتي الاحتمالية والأثر (درجة الخطر = الاحتمالية × الأثر)، بهدف تركيز الموارد على معالجة المخاطر الأكثر خطورة. وتقع الأولوية القصوى على المخاطر الموجودة في مربع الاحتمالية العالية والأثر العالي. يوضح الجدول أدناه مصفوفة تصنيف المخاطر (Matrix 5×5) المعتمدة رسمياً في البنك:

IMPACT	Catastrophic	5	5	10	15	20	25
	Major Disruption	4	4	8	12	16	20
	Moderate / Workaround	3	3	6	9	12	15
	Minor / Inconvenience	2	2	4	6	8	10
	Insignificant	1	1	2	3	4	5
			1	2	3	4	5
			Remote	Unlikely	Possible	Probable	Highly Probable
			LIKELIHOOD				

- اللون الأحمر (Red - Extreme Risks): مخاطر بالغة الخطورة تهدد استمرارية عمليات ووجود البنك (الدرجات 16 إلى 25). تتطلب تدخلاً فورياً وحاسماً.
- اللون العنبري / البرتقالي (Amber - Moderate/High Risks): مخاطر متوسطة إلى مرتفعة تهدد العمليات والخدمات المصرفية (الدرجات 11 إلى 15). تتطلب خطة معالجة عاجلة.
- اللون الأصفر (Yellow - Lower Risks): مخاطر أقل قد تسبب إزعاجاً تشغيلياً ولكن يمكن التكيف معها وإدارتها (الدرجات 5 إلى 10). تتطلب مراجعة إدارية.
- اللون الأخضر (Green - Insignificant Risks): مخاطر ضئيلة يجب معالجتها روتينياً ولكنها لا تسبب أي مشكلات تشغيلية ملحوظة (الدرجات 1 إلى 4).

معالجة وتخفيف المخاطر (Risk Mitigation)

سيقوم فريق أمن المعلومات بعد ذلك بتطوير استراتيجيات لإدارة المخاطر التي تم تحديد أولوياتها. وتوجد أربعة أساليب رئيسية لمعالجة المخاطر:

- القبول (Accept): إذا كان احتمال حدوث الخطر وأثره منخفضين، فقد يكون من المقبول الإقرار به ومراقبته.
- التجنب (Avoid): إن أمكن، قم بتعديل الخطط لتجنب الخطر تماماً.
- النقل / التحويل (Transfer): نقل عبء الخطر إلى طرف آخر (على سبيل المثال: من خلال التأمين أو الاستعانة بمصادر خارجية).

- التخفيف / الحد من الخطر (Mitigate): تطبيق إجراءات وتدابير لتقليل احتمالية حدوث الخطر و/أو الحد من أثره (على سبيل المثال: تقديم تدريب إضافي، ووضع خطط بديلة/احتياطية، وتنويع الموردين).

يتم إنشاء ومراقبة خطط تخفيف المخاطر وتعيين مالك مسؤول عن تنفيذ كل خطة لخفض الخطر إلى مستوى مُرضٍ ومقبول يتماشى مع شهية المخاطر المعتمدة لبنك الآفاق الرقمية.

يجب أن يوثق سجل المخاطر (Risk Log) بوضوح خيارات المعالجة المختارة، مع تقديم تبرير موضوعي لكل قرار استناداً إلى نتائج التقييم والشهية للمخاطر وفق الجدول التالي:

خيار المعالجة (Treatment) (Option)	متطلبات التوثيق الإلزامية في سجل المخاطر (Documentation)
القبول (Accept)	تقديم مبرر كتابي مفصل لقبول الخطر، متضمناً تحليلاً للتكلفة مقابل العائد (Cost-Benefit Analysis) وموافقة الإدارة المعنية.
التجنب (Avoid)	توصيف دقيق للتغييرات التي أجريت على الخطط أو الإجراءات أو الأنظمة المصرفية لتفادي الخطر وإلغاء مسبباته بالكامل.
النقل (Transfer)	تفصيل الآليات والاتفاقيات المعتمدة لنقل الخطر، مثل وثائق التأمين السيبراني أو عقود الإسناد الخارجي ومستويات الخدمة SLA.
التخفيف (Mitigate)	تحديد الإجراءات والضوابط المحددة المتخذة لتقليل الخطر، بما في ذلك الضوابط التقنية، الإدارية، والمادية المستمدة من الملحق A لمواصفة ISO 27001.

يجب تسجيل جميع قرارات معالجة المخاطر في سجل المخاطر، واعتمادها رسمياً من قبل مالك الخطر المعني، ومراجعتها وتأكيداتها من قبل مدير أمن المعلومات (ISO/CISO).

معايير قبول المخاطر (Risk Acceptance Criteria):

تُعرف معايير قبول المخاطر بأنها مستوى الخطر الذي يكون بنك الآفاق الرقمية مستعداً لتحمله وقبوله دون الحاجة إلى تطبيق تدابير تخفيف إضافية. وتعتمد هذه المعايير رسمياً من الإدارة العليا وفق الاستراتيجية المصرفية والشهية للمخاطر:

مستوى وفئة الخطر (Criteria)	معايير القبول والتعامل المعتمد (Acceptance Rule)
المخاطر المنخفضة (Score 1-4): Low Risks	مقبولة دون الحاجة إلى معالجة إضافية، ولكن يجب مراقبتها دورياً لضمان عدم تصاعدها.
المخاطر المتوسطة (Score 5-10): Medium Risks	يجوز قبولها استثنائياً فقط إذا كانت تكلفة المعالجة تفوق الفوائد المترتبة عليها. يتطلب ذلك موافقة إدارية خطية صريحة.
المخاطر العالية (Score 11-15): High Risks	تتطلب تدابير وضوابط تخفيفية إلزامية لخفض مستوى الخطر إلى الحد المقبول. لا يجوز قبولها إطلاقاً دون خطة معالجة شاملة ومعتمدة.
المخاطر الحرجة (Score 16-25): Critical Risks	غير مقبولة على الإطلاق (Unacceptable). تتطلب اتخاذ إجراءات فورية وطارئة لتخفيف الخطر أو نقله دون أي تأخير.

تتم مراجعة واعتماد هذه المعايير سنوياً من قبل لجنة أمن المعلومات والمخاطر (ISG)، وتتم إعادة النظر فيها فور حدوث أي تغييرات جوهرية في سياق البنك أو متطلبات البنك المركزي السعودي.

مراقبة المخاطر (Risk Monitoring):

تخضع المخاطر للمراقبة والمراجعة المستمرة، مع توثيق تحديثات تقييم المخاطر كلما تطور الموقف، وتعديل خطط المعالجة والتخفيف تبعاً لذلك.

تساعد المراجعات الدورية للمخاطر في ضمان اتخاذ نهج استباقي في إدارة المخاطر والحفاظ على فاعلية المنهجية المتبعة.

خطط المعالجة التفصيلية (Treatment Plans)

في إطار نهجنا لإدارة مخاطر أمن المعلومات والحد منها، نعتمد استراتيجية قائمة على تحديد عتبات تقييمية تضمن التعامل مع كل خطر بمستوى التفصيل والاهتمام المناسب له.

وفقاً للتقييم المشترك للاحتماالية والأثر، فإن المخاطر المقاسة كمياً الحاصلة على درجة تزيد عن عشر درجات تستوجب إعداد خطة شاملة لمعالجة المخاطر. وتوفر هذه الخطط استراتيجيات وإجراءات متعمقة ومخصصة تتناسب مع الطبيعة المحددة ومدى التعقيد لكل خطر ذي درجة مرتفعة، بما يضمن معالجة فعالة وقوية.

أما بالنسبة للمخاطر التي تحصل على تسع درجات أو أقل، فسيتم توثيق استراتيجيات المعالجة والضوابط الرقابية الخاصة بها مباشرة داخل سجل المخاطر. ويتيح لنا هذا النهج الحفاظ على سجل مخاطر موجز وقابل للإدارة بسلاسة، مع توجيه التخطيط التفصيلي والموارد نحو المخاطر التي تشكل تهديداً أكبر للوضع الأمني للمعلومات في منظمنا.

تتماشى هذه المنهجية مع التزامنا بإجراءات استباقية ومحددة الأولويات في إدارة المخاطر، مما يضمن معالجة المخاطر الأكثر أهمية وخطورة عبر خطط معالجة شاملة ودقيقة.

التصعيد الإداري للمخاطر (Escalation)

يجب تصعيد أي خطر يُصنف ضمن فئة «رئيسي» (Major) عبر الهيكل الإداري ليُدرج في سجل مخاطر المنظمة (Corporate Risk Register).